

SIMATS ENGINEERING
ASSESSMENT TOOL 3 – CASE STUDY

COURSE CODE: ITA14

COURSE NAME: Ethical Hacking

COURSE OUTCOME COVERED

CO4: Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux. (BT4, BT5)

Assessment Tool Weightage: 35%

QUESTIONS: 5

Total Marks:100

1. A mid-sized e-commerce company hosts its web application on an Apache server running on a Linux environment. Recently, customers reported unauthorized transactions and abnormal account activities. Upon investigation, the IT team discovered suspicious HTTP requests in server logs, including attempts to access hidden directories and injection of malicious scripts into input fields. Additionally, the server is running an outdated version with known vulnerabilities, and no Web Application Firewall (WAF) is implemented. As a cybersecurity analyst, you are tasked with conducting a comprehensive security assessment using Kali Linux. Analyze the possible attack vectors exploited by the attacker, including web server vulnerabilities, input validation issues, and outdated software components. Explain in detail how you would perform reconnaissance, vulnerability scanning, and exploitation using appropriate Kali Linux tools. Further, propose a layered defense strategy that includes server hardening, secure coding practices, and network-level protections to prevent such incidents in the future.

AIM

To perform a security assessment of an authorized e-commerce web server using Kali Linux tools and identify web-server, input-validation, and outdated-software vulnerabilities.

PROCEDURE

1. Perform reconnaissance to collect information about the target.
2. Identify active hosts, open ports, services, and versions using Nmap.
3. Identify web technologies using WhatWeb.
4. Examine HTTP response headers using Curl.
5. Scan the web server for common vulnerabilities using Nikto.
6. Discover publicly accessible directories using Gobuster.
7. Analyze input fields and requests using Burp Suite.
8. Identify possible vulnerabilities such as outdated software, XSS, and improper input validation.

9. Assess the impact and recommend server, application, and network-level security controls.

10. Document the findings with screenshots and observations.

COMMANDS

```
nmap -sC -sV <target-ip>
```

```
whatweb http://<target-ip>
```

```
curl -I http://<target-ip>
```

```
nikto -h http://<target-ip>
```

```
gobuster dir -u http://<target-ip> -w <wordlist>
```

OBSERVATION

The assessment identifies open services, Apache version information, web technologies, HTTP headers, accessible directories, and potential web-server misconfigurations.

FINDINGS

- Outdated Apache version
- Hidden or unnecessary directories
- Improper input validation
- Possible XSS vulnerability
- Lack of WAF
- Insufficient security controls

RESULT

The authorized e-commerce web server was successfully assessed using Kali Linux tools. The assessment identified potential attack surfaces and security weaknesses, and appropriate hardening measures were recommended.

2. A financial services web application allows users to log in, view account details, and perform transactions. A recent penetration test revealed that the application is vulnerable to SQL injection and Cross-Site Scripting (XSS) attacks. Error messages expose database structure information, and user inputs are not properly sanitized. Attackers have exploited these weaknesses to extract sensitive customer data and inject malicious scripts into web pages viewed by other users. You are assigned to perform a detailed security audit of the application. Question: Examine how SQL injection and XSS vulnerabilities can be exploited in this scenario. Describe a step-by-step methodology using Kali Linux tools such as Burp Suite and SQLmap to identify and validate these vulnerabilities. Evaluate the impact of such attacks on confidentiality, integrity, and availability (CIA triad). Recommend comprehensive mitigation strategies, including input validation, output encoding, secure session handling, and implementation of security controls.

AIM

To identify and assess SQL Injection and Cross-Site Scripting vulnerabilities in an authorized financial web application using Kali Linux security tools

PROCEDURE

1. Identify the application's technologies and services.
2. Scan the authorized application using Nmap.
3. Identify web technologies using WhatWeb.
4. Configure Burp Suite and capture normal application requests.
5. Examine input fields, parameters, cookies, and sessions.
6. Analyze database-related error messages.
7. Use SQLmap only on the authorized laboratory application to validate approved test parameters.
8. Analyze application responses for possible XSS behavior.
9. Evaluate the impact using the CIA triad.
10. Recommend secure coding and application-security controls.

COMMANDS

```
nmap -sC -sV <target-ip>
```

```
whatweb http://<target-ip>
```

```
curl -I http://<target-ip>
```

Authorized SQLmap validation:

```
sqlmap -u "<authorized-test-url>" --batch
```

OBSERVATION

Burp Suite can display HTTP requests, parameters, cookies, headers, and responses. SQLmap can help validate approved SQL-injection test parameters in the laboratory.

CIA ANALYSIS

Security Property	Impact
Confidentiality	Sensitive customer information may be exposed
Integrity	Unauthorized modification of information may occur
Availability	Improper requests may affect application availability

RESULT

The authorized application was assessed for SQL Injection and XSS risks. The assessment demonstrated the importance of input validation, parameterized queries, output encoding, secure session management, and proper error handling.

3. A corporate office provides wireless internet access to employees using WPA2-PSK authentication. Recently, several employees reported unusual login prompts and slow network performance. A security investigation revealed the presence of a rogue access point (Evil Twin) mimicking the official network SSID. Attackers used this setup to capture login credentials and perform man-in-the-middle (MITM) attacks. You are tasked with analyzing the breach and strengthening wireless security. Explain how the attacker successfully executed the Evil Twin attack and intercepted sensitive data. Describe how Kali Linux tools such as Aircrack-ng and Wireshark can be used to detect and analyze such attacks. Evaluate the weaknesses in the existing wireless security configuration. Propose robust countermeasures, including secure authentication mechanisms, network monitoring, and user awareness strategies.

AIM

To analyze an Evil Twin attack against an authorized corporate wireless network and identify methods for detecting and preventing rogue access points.

PROCEDURE

1. Identify the legitimate wireless network in the authorized laboratory.
2. Observe the network SSID, BSSID, channel, and security configuration.
3. Use Aircrack-ng tools to analyze the wireless environment.
4. Use Wireshark to examine authorized wireless traffic captures.
5. Identify indicators of duplicate or rogue access points.
6. Analyze how users could be redirected toward a fraudulent network.
7. Examine the weaknesses of WPA2-PSK authentication.
8. Evaluate the risks of credential interception and MITM attacks.
9. Recommend stronger wireless authentication and monitoring.
10. Document observations and screenshots.

COMMANDS

airmon-ng

airodump-ng <monitor-interface>

Wireshark can be opened from Kali Linux to analyze an authorized packet capture.

OBSERVATION

A rogue access point may imitate the legitimate SSID and cause users to connect to an unauthorized wireless network. Duplicate SSIDs, unexpected BSSIDs, unusual login prompts, and certificate warnings can indicate an Evil Twin.

SECURITY WEAKNESSES

- Shared WPA2-PSK credentials
- Lack of enterprise authentication

- Lack of rogue AP monitoring
- Insufficient user awareness
- Possible MITM exposure

RESULT

The wireless environment was analyzed using Aircrack-ng and Wireshark. The assessment demonstrated the risks associated with rogue access points and highlighted the need for enterprise wireless authentication and continuous monitoring.

4. An organization's internal network hosts a web-based employee management system accessible over Wi-Fi. The wireless network uses weak passwords, and the web application lacks proper authentication and session management. An attacker gains access to the Wi-Fi network, performs reconnaissance, and exploits vulnerabilities in the web application to escalate privileges and access confidential employee data. You are assigned to perform a full penetration testing assessment. Analyze the attack chain starting from wireless network compromise to web application exploitation. Describe each phase of the attack, including reconnaissance, scanning, exploitation, and privilege escalation. Demonstrate how Kali Linux tools can be used in each phase. Propose a comprehensive security framework that addresses both wireless and web application vulnerabilities, ensuring defense-in-depth.

AIM

To analyze an authorized attack scenario in which a weak wireless network provides an entry point to a vulnerable employee-management web application.

PROCEDURE

1. Assess the security of the authorized wireless network.
2. Identify active hosts using Nmap.
3. Identify open ports and services.
4. Identify the web server and technologies.
5. Scan the web server using Nikto.
6. Analyze application requests using Burp Suite or OWASP ZAP.
7. Examine authentication and session-management controls.
8. Analyze authorization and privilege-management weaknesses.
9. Evaluate the possible impact on confidential employee information.
10. Recommend defense-in-depth security measures.

COMMANDS

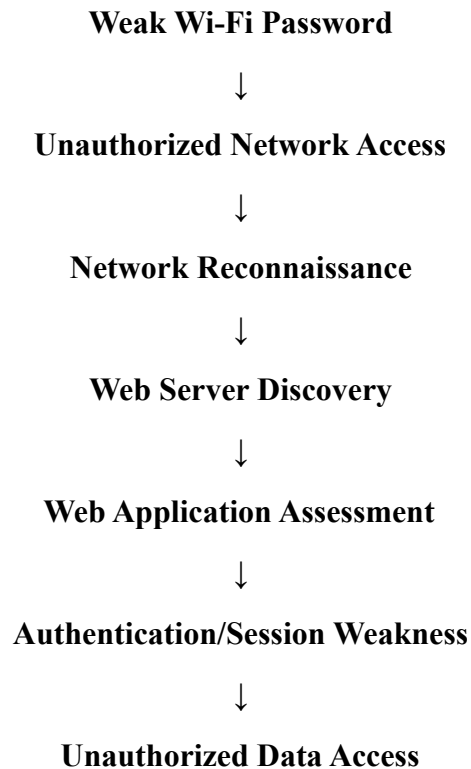
```
nmap -sn <network-range>
```

```
nmap -sC -sV <target-ip>
```

```
whatweb http://<target-ip>
```

```
nikto -h http://<target-ip>
```

ATTACK CHAIN



OBSERVATION

Weak wireless authentication can provide initial network access. If the web application also contains authentication, session, or authorization weaknesses, an attacker may be able to progress from network access toward sensitive employee information.

SECURITY MEASURES

- WPA2/WPA3-Enterprise
- 802.1X authentication
- Network segmentation
- Strong passwords
- MFA
- Secure session management
- Server-side authorization
- HTTPS
- Continuous monitoring

RESULT

The complete attack chain was analyzed from wireless compromise to potential web-application abuse. The assessment demonstrated the importance of implementing defense-in-depth across both wireless and web environments.

5. A university campus experiences frequent Wi-Fi disruptions during peak hours. Investigation reveals repeated deauthentication attacks targeting access points, causing legitimate users to disconnect. The attacker uses automated tools to continuously send deauth packets, leading to denial of service. You are tasked with identifying the cause and implementing solutions. Explain how deauthentication attacks are carried out in wireless networks and how attackers exploit protocol weaknesses. Describe how Kali Linux tools can be used to simulate and analyze such attacks in a controlled environment. Evaluate the impact on network availability and user productivity. Recommend effective mitigation strategies, including network configuration changes, intrusion detection systems, and secure wireless protocols.

AIM

To analyze deauthentication attacks in an authorized wireless laboratory and evaluate their impact on network availability.

PROCEDURE

1. Identify the authorized wireless network.
2. Observe connected clients and access points.
3. Use Aircrack-ng tools to monitor wireless traffic.
4. Capture authorized wireless traffic for analysis.
5. Use Wireshark to examine management-frame activity.
6. Identify repeated client disconnections.
7. Analyze the effect on network availability.
8. Determine the security weaknesses that allow such disruption.
9. Recommend Protected Management Frames and wireless monitoring.
10. Document the observations, screenshots, impact, and recommendations.

COMMANDS

airmon-ng

airodump-ng <monitor-interface>

Wireshark:

Applications → Sniffing & Spoofing → Wireshark

OBSERVATION

Repeated deauthentication activity can cause legitimate wireless clients to disconnect from an access point. Continuous disruption may result in poor network performance and loss of connectivity.

IMPACT

Area	Impact
Availability	High
User productivity	Reduced
Network performance	Reduced
Business/academic operations	Disrupted

SECURITY MEASURES

- Enable Protected Management Frames (PMF/802.11w).
- Use WPA3 where supported.
- Deploy WIDS/WIPS.
- Monitor wireless management traffic.
- Update access-point firmware.
- Segment critical wireless networks.
- Investigate repeated disconnection events.

RESULT

The deauthentication attack scenario was analyzed in an authorized laboratory environment. The assessment demonstrated its effect on wireless availability and identified PMF, WPA3, wireless intrusion detection, and continuous monitoring as important countermeasures.

Code of Conduct:

I SURU SAI KEERTHI[192424368] (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: